#62 【AIセキュリティのプロ】個人情報が簡単に奪われる現代で最強のセキュリティ対策は？

https://www.youtube.com/watch?v=K3DwuE_9bps ／ 55:35

3行要約

- セキュリティの専門家（数百万人規模のサービスを守ってきたエンジニア）をゲストに迎え、AI時代の攻撃の実態と、個人・会社でできる対策を聞く回（入門編は→#42）。
- AIのおかげで攻撃者は弱点探しや日本語の詐欺メールを大量に作れるようになり、これまで「日本語の壁」に守られていた日本が急に狙われている。
- 個人の最低限の対策は「2段階認証」と「パスキー」。会社では、急ぎの送金指示を別の手段で必ず本人確認するルールが重要。

主なポイント

- 安全装置を外した中国製モデルを小さくして個人PCで動かし、攻撃に使える可能性がある。今後は「安全装置なしのAI」が月額サービスとして闇で売られる恐れも。
- 大量アクセスでサイトを落とす攻撃、身代金要求型ウイルス（ランサムウェア）などはすでにサービスとして売買され、国内大手企業も被害を受けている。
- AI以前は、知られていない弱点（ゼロデイ）を見つけるのはプロの仕事だったが、今はAIが大量に試して見つけてしまう。攻撃は「100回中1回成功すればよい」、防御は「100回全部防ぐ」必要があり、攻撃側が有利。
- 🔑 **詐欺メールの多くが日本向けになった。** 以前は日本語が難しく見逃されていたが、AIで自然な日本語が書けるようになったため。会社の代表アドレスから推測した宛先に一斉送信される。
- 放置されたWebサイト（WordPressなど）は侵入されやすく、勝手に高額なサーバーを立てられて仮想通貨の採掘に使われ、高額請求が来る例も。
- 🔑 **「自分の情報なんて価値がない」は誤り。** アカウントを乗っ取られると、あなたの信用を使って家族・友人・取引先に「お金を貸して」などの詐欺が広がる。
- 🔑 **個人の対策：2段階認証を必ず設定し、さらに「パスキー」（顔や指紋でログインする方式）も使う。** パスワードだけの状態を1とすると、2段階認

証で10、パスキーで50くらいの強さ。偽サイトにパスワードを入力させる手口も、パスキーなら防ぎやすい。

- 🔑 **会社の対策：社長や警察などを名乗り「至急ここへ送金して」と急かす詐欺が増えている。** 急ぎの送金依頼は、対面や電話など別の経路で必ず確認する流れを決めておく。送金できる人を限定するのも有効。
- AIでアプリを作っても、安全に公開するのは難しい。今回はゲストと共同で、セキュリティ対策済みの環境でAIアプリを作って社内や取引先限定で公開できる「VibeBox」（非公開・限定提供）を紹介。

紹介されたテクニック

- **2段階認証を必ず設定する**：メール・SNS・銀行などで、パスワードに加えて認証アプリ（数字を入力する方式）やスマホでの確認を求める設定をオンにする。パスワードは総当たり（機械的に組み合わせを試す攻撃）でいつか破られる前提で考えるため。
- **パスキーも設定する**：サービスに「パスキーを設定しましょう」と出たらスキップせずに設定し、指紋や顔認証でログインする方式にする。パスワード自体が不要になり、1文字違いの偽サイトに入力させる手口にも強い（強さの目安：パスワードだけ＝1、2段階認証＝10、パスキー＝50）。
- **「自分は狙われない」と思わない**：乗っ取られたアカウントは、本人の信用を使って家族・友人・取引先に「少しお金を貸して」とDMを送る詐欺に使われる。影響力のある人ほど、上の2つを優先して設定しておく。
- **急ぎの送金指示は別の経路で確認するルールを作る**：チャットツール（TeamsやSlackなど）に社長や警察を名乗るアカウントから「至急ここへ送金して」と急かす連絡が来たら、対面や電話など別の手段で本人確認してから動く流れを社内で決めておく。
- **送金できる人と金額を限定する**：社員が少額以上の振込をできないよう権限を絞る、振込を税理士など外部に任せる、といった形にすると、なりすまし指示が来ても物理的に送金できない。外部に任せる場合は、そちらにもこの詐欺の手口を共有しておく。
- **銀行などからのログイン依頼メールのリンクは疑う**：1文字違いの偽サイトに誘導してパスワードを入力させる手口（フィッシング）があるため、メールのリンクから直接ログインしない。
- **作りっぱなしのWebサイトを放置しない**：制作会社に作ってもらったまま更新していないサイト（WordPressなど）は侵入されやすく、勝手に高性能なサーバーを立てられて仮想通貨の採掘に使われ、高額請求が来ることもある。使わないサイトは止めるか、保守（更新）を続ける。

- **AIで作ったアプリは、守りの仕組みがある環境で限定公開する**：アクセスを自社ドメインのメールを持つ人や取引先だけに絞る、よくある攻撃を防ぐ仕組みを入れる、AIを隔離された環境（サンドボックス＝外に影響が出ない箱）で動かす、などの対策が必要。動画では、それらを組み込んだ社内向け環境「VibeBox」（非公開・限定提供）が紹介された。

紹介されたツール Kimi（中国製）、Claude Mythos／Fable、WordPress、AWS・Google Cloud・Cloudflare、パスキー、2段階認証（認証アプリ）、VibeBox（限定提供）

すぐ実践できること

- よく使うサービス（メール、SNS、銀行、AI）で2段階認証とパスキーを今日設定する。
- 会社なら「急ぎの送金依頼は必ず電話か対面で本人確認」とルールを決め、全員に共有する。